PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Vols de cookies, logiciels non maîtrisés et exfiltration

03-1210 CERT-FR - Retours d'expérience, vols de cookies, logiciels non maîtrisés et exfiltration de données — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le vol de cookie de session permet d'usurper l'identité d'un utilisateur en contournant l'authentification multifacteur.
2. Un logiciel non maîtrisé doit être installé dans une zone isolée avec un filtrage des flux au juste besoin.
3. Les accès légitimes constituent le premier vecteur d'exfiltration massive de données personnelles.

Les vols de cookies

Notion	À retenir
Une menace croissante	Cibles privilégiées pour accès comptes et **latéralisation** (cloud). Volés par **stealers** ou **hameçonnage**, revendus sur **Genesis** ou **Russian Market**. Contournent l'**authentification multifacteur**.
Des exemples	**Lapsus$** (Okta mars 2022, Electronic Arts juin 2021, usurpation Slack). Mode opératoire **Nobelium**.
Les contre-mesures	Limiter **durée de validité** (quelques minutes pour accès sensibles), exiger **réauthentification** (opérations sensibles), détecter **incohérences** (IP, horaires), **journaliser** les actions et durcir le **SI d'administration**.

Synthèse des logiciels non maîtrisés

Notion	À retenir
Cas GoldenSpy	Logiciel chinois de TVA **Golden Tax** (Aisino/Baiwang) avec porte dérobée **GoldenSpy** (révélée par Trustwave, **juin 2020**). S'exécutait **2 heures** après installation avec **privilèges élevés**, persistait après désinstallation, puis effacé discrètement.
Chaîne d'approvisionnement	L'éditeur peut être compromis : exemple de **NotPetya** distribué via une mise à jour du logiciel **M.E.Doc**.
Recommandations	Installer en **zone isolée** (équipements/cloud dédiés), filtrer les flux au **juste besoin** (pare-feu distinct), appliquer le **moindre privilège** et maintenir la **cartographie**.

Exfiltration de données du secteur social

Notion	À retenir
Le constat	En **2023** et **début 2024**, **183** incidents d'exfiltration traités par le CERT-FR, dont **60** liés à un **rançongiciel**. **9** entités sociales appuyées hors rançongiciel (données de **millions** de Français).
Les failles	Les **accès légitimes** sont le **premier vecteur** : identifiants **partagés**, **réutilisés** ou **sans authentification forte** (volés/achetés), comptes **prestataires** sans MFA ; un prestataire a même **volontairement** exfiltré une base avec ses accès administrateur.
Les recommandations	Utiliser l'**authentification multifacteur** pour tout usager accédant aux données d'un tiers. **Journaliser**, **désactiver** les comptes inutilisés, **interdire** les comptes génériques et **limiter** les plages d'accès.

Pièges et confusions

- ⚠ Croire qu'un cookie de session volé nécessite la connaissance du mot de passe
- ⚠ Penser qu'un logiciel imposé ne nécessite pas d'être confiné dans une zone isolée
- ⚠ Considérer que l'authentification multifacteur protège contre le vol de cookie de session
- ⚠ Oublier que la journalisation et la détection des comportements anormaux sont indispensables
- ⚠ Ignorer que les accès légitimes sont le premier vecteur d'exfiltration massive

Sigles et définitions

Cookie	Petit couple clé et valeur conservé par le navigateur pour maintenir une session authentifiée
SSO	Authentification unique donnant accès à plusieurs services après une seule authentification
JWT	Jetons de session sans état où le cookie se suffit à lui-même
Logiciel non maîtrisé	Logiciel imposé ou externe dont on ne contrôle ni le code ni les mises à jour
Usager applicatif	Personne ayant un accès à une application, interne ou externe à l'organisation
Privacy by Design and by Default	Protection des données dès la conception et par défaut prévue par l'article 25 du RGPD

Auto-test

1. Quel est l'avantage d'un cookie de session volé pour un attaquant ?
2. Quel logiciel présentait une porte dérobée nommée GoldenSpy ?
3. Combien d'incidents d'exfiltration ont été traités en 2023 et début 2024 ?
4. Quel logiciel a été utilisé pour distribuer NotPetya via une mise à jour ?
5. Que faut-il utiliser pour tout usager accédant aux données d'un tiers ?

Réponses : **1.** Usurper l'identité d'un utilisateur sans connaître son mot de passe · **2.** Golden Tax · **3.** 183 · **4.** M.E.Doc · **5.** L'authentification multifacteur

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.